

차세대 인증 기술 -FIDO

[참고] - 보안사고 사례1

➤ 비밀번호 기반 인증 방식의 취약점을 악용한 사례

인류의 '절반'? "비밀번호 등 인증정보 유출"

✎ 전문미 기자 | ⓒ 입력 2025.06.19 23:28 | 🔍 댓글 0



소셜미디어 등에서 사상 최대 160억개 비번과 인증정보 유출
애플, 페이스북, 구글, 텔레그램, 깃허브, VPN, 이메일, 공공포털 등 털려
'악성 SW, 사용자 컴퓨터에 침투, 자격 증명, 쿠키, 세션 토큰 등 훔쳐'



[애플경제 전문미 기자] 무려 160억개의 패스워드와 인증정보가 유출된 사상 최대 규모의 데이터 도난 사건이 벌어졌다. 애플, 페이스북, 구글, 텔레그램, 깃허브, VPN 등은 물론, 일부 국가의 정부 포털까지 포함한 플랫폼에서 이런 어마어마한 숫자의 비밀번호들이 무더기로 유출되었다.

이들 소셜미디어 사용자들이 대부분 피해자가 될 수 있는 만큼 전 세계적으로 그 숫자를 가늠하기조차 어려운 상황이다. 이 역시 정보 유출 악성코드 공격의 결과로 추정된다.

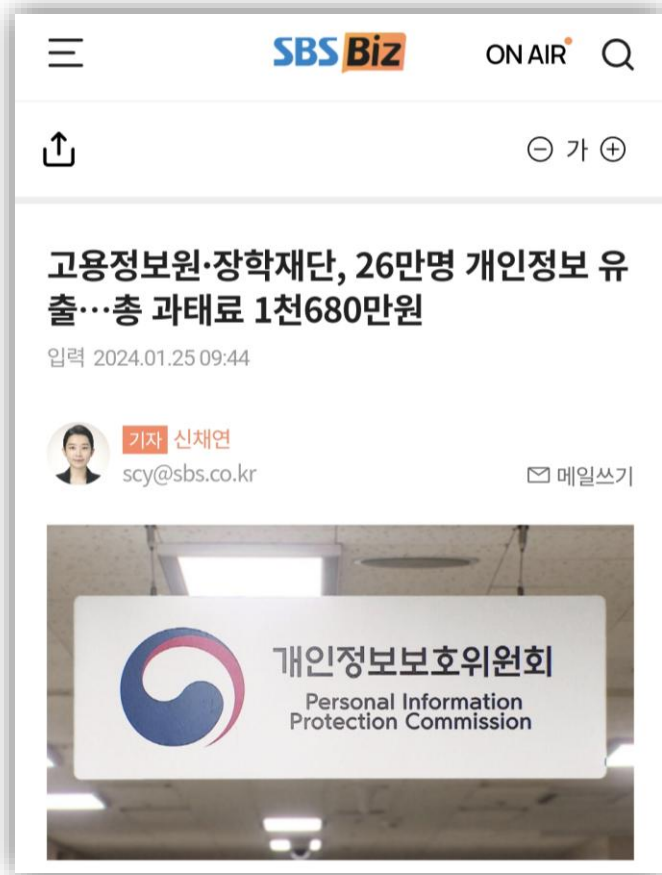
피해자들, "적게는 수천만 건, 많게는 35억명"

보안매체이자 전문기관인 사이버뉴스(Cybernews)에 따르면 이번에 데이터가 유출된 피해자들은 적게는 수천만 건에서 많게는 35억명에 달할 것으로 추정된다. 이들의 기록을 망라한 30개의 초대형 데이터 세트에서 도난 사건이 발생한 것이다. 최악의 경우 전 인류의 절반이 피해를 입을 수도 있다는 추측도 나온다.

공격자들이 훔쳐낸 비밀번호 등 인증정보는 다시 한데로 취합되어, 대규모 저장소에 저장된 후 사이버 범죄 포럼과 지하 시장에서 거래될 것으로 보인다. 이들 데이터 세트는 URL, 로그인, 비밀번호 등을 망라한다. 다들 해커들이 사용자들의 계정을 탈취할 수 있는 무기가 될만한 것들이다.

[참고] – 보안사고 사례2

➤ 비밀번호 기반 인증 방식의 취약점을 악용한 사례



개인정보위는 지난해 6~7월 한국고용정보원의 '워크넷'(구인·구직 사이트)에 신원 미상의 자가 '크리덴셜 스테핑' 방식으로 침입해 23만 6천여 명의 개인정보가 유출된 사실을 확인했습니다.

한국장학재단 홈페이지의 경우에도 동일한 방식에 의해 3만 2천여 명의 개인정보가 유출된 사실이 확인됐습니다.

크리덴셜 스테핑은 공격자가 다른 방법을 통해 계정, 비밀번호 정보를 취득한 후 또 다른 사이트에서도 이를 동일하게 사용해 성공할 때까지 로그인을 시도하는 대입 공격 중 하나입니다. 로그인 시도 횟수와 로그인 실패율이 급증하는 특징을 보입니다.

두 기관 모두 24시간 감시·모니터링 체계는 갖추고 있었지만 크리덴셜 스테핑 공격에 대응할 수 있는 보안대책(로그인 시도가 일정 횟수 이상 실패할 경우 계정 잠금, 암호 외 문자·OTT 인증 추가 등 2단계 이상 인증 등)은 미흡했던 것으로 밝혀졌습니다.

[참고] – 보안사고 사례3

➤ 피싱 공격에 따른 사고 사례

'피싱 범죄' 온상 된 텔레그램... "출처불명 링크 누르면 뉘여"[인사이드&인사이드]

동아일보 업데이트 2023-07-31 23:43

확산되는 텔레그램 해킹 파문

운영자-지인 사칭해 접속... '업데이트 하라' 접속 유도

7월 피싱사이트 10곳 차단... 해킹용 링크 250만개 달해

개인정보로 금융사기 우려... "지인 보낸 링크도 조심할"

텔레그램 피싱 특징

• 업데이트 요구

"이전 버전은 해킹에 취약하니
서둘러 업데이트를 해주세요"

• 계정 재인증·재로그인 요구

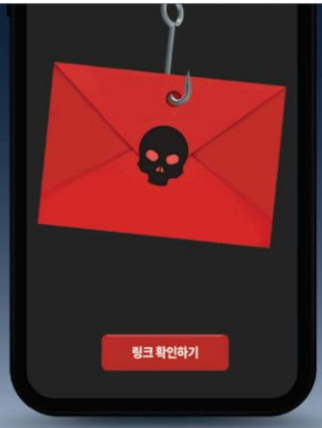
"불법 사용이 발견됐으니
24시간 이내 재로그인하세요"

"계정 재인증을 위해
전화번호를 입력하세요"

• 공식 사이트와 유사한 URL 사용

'telegram.org' 'telegim'
'teigram' 등 유사 주소 통해
접속 유도

자료: 한국인터넷진흥원, 안랩 등



목표 계정을 확보한 해커들은 서비스 운영자로 위장하거나 지인을 사칭해 사용자에게 접근한다. 주 공격 루트는 일대일 대화창이었다. 이들은 '불법 사용이 발견됐으니 24시간 내 재로그인하라', '계정 재인증을 위해 전화번호를 입력하라', '링크를 눌러 업데이트를 실행하라' 등의 내용으로 메시지 내 피싱 사이트 링크로 접속하도록 유도했다.

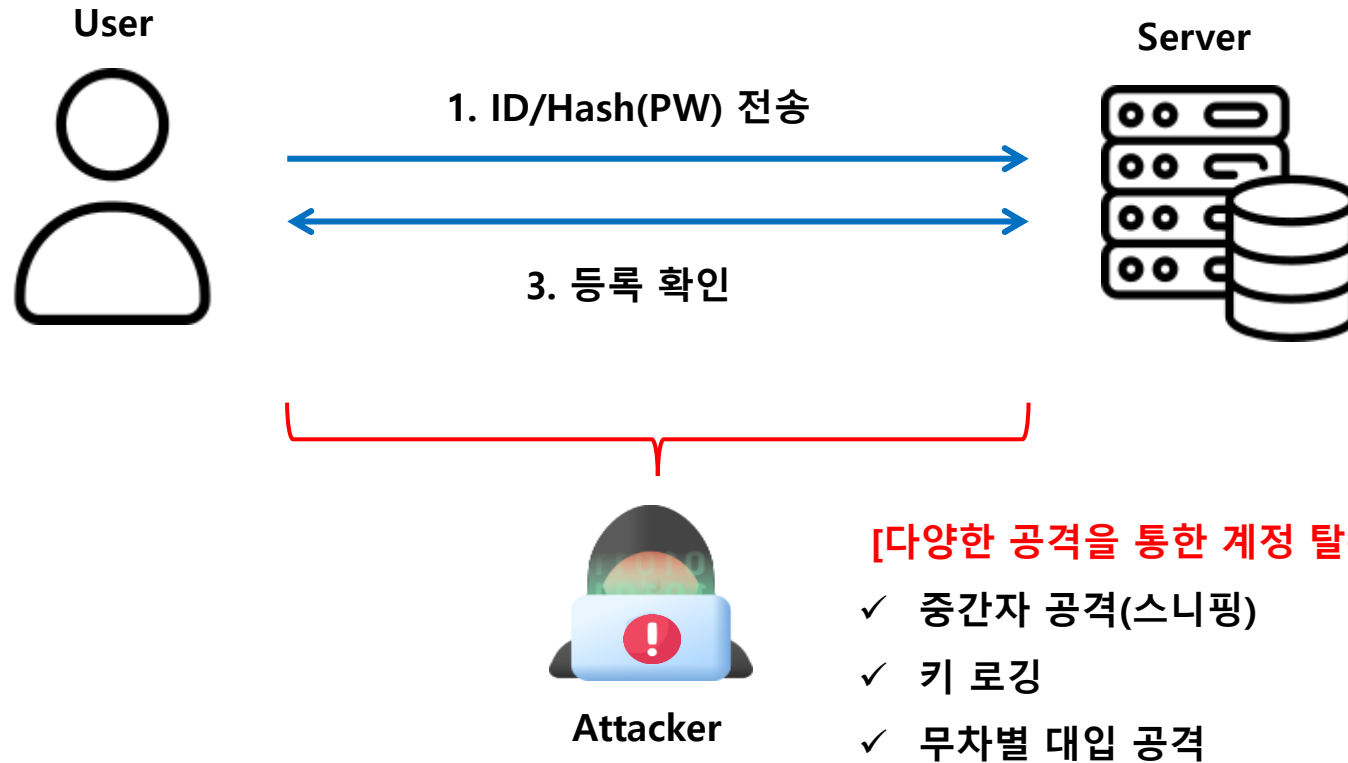
피싱 사이트 링크로는 텔레그램 공식 웹사이트 주소와 매우 유사한 형태의 URL(인터넷주소)이 활용됐다. 알파벳 'o'를 숫자 '0'으로 바꾼 telegram.org를 이용하기도 했고, 'telegram'을 'telegim', 'teiegrim', 'telegramvip' 등으로 일부 철자를 바꾸며 교묘하게 사용자들을 속였다. 피싱 사이트 디자인 역시 정상적인 텔레그램 서비스 로그인 페이지와 사실상 차이가 없는 수준이었다.

사용자가 무심코 피싱 사이트에 휴대전화 번호를 입력하면, 해커들은 그 번호를 실제 텔레그램 사이트에 입력해 사용자에게 인증코드를 전송하게 했다. 안랩 관계자는 "사용자가 해당 인증코드를 피싱 사이트에 입력하면 해커들은 사용자 계정에 완전한 접근권을 갖게 된다"며 "해커들은 계정 탈취 후 다시 해당 계정의 지인들에게 피싱 메시지를 재유포하는 것으로 나타났다"고 밝혔다.

기존 인증 시스템

➤ 패스워드 기반 인증

⚠ 비밀번호를 자주 생성하고
기억해야 하는 번거로움 존재



2. DB에 ID/PW 저장

Index	ID	Hash(PW)
1	user1	Hash('inf0sec')
...	...	...
301	alice	Hash('hoseo134')

⚠ 사용자 계정 정보가 서버에 저장됨

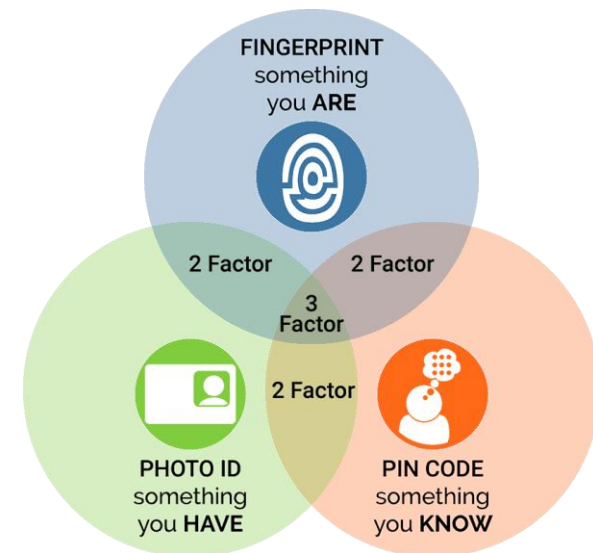
기존 인증 시스템

➤ 다중 요소 인증(Multi Factor Authentication, MFA)

- 패스워드 기반 인증 문제를 해결하기 위한 인증 방식
- 기존 사용하던 인증 수행 후, **다른 인증 요소**를 활용하여 **추가 인증**을 수행하는 것
 - ex) 비밀번호(지식 기반) + SMS OTP(소유 기반)
 - 비밀번호(지식 기반) + PIN(지식 기반)과 같이 동일한 요소를 통한 다중 인증은 MFA가 아님

[사용자 인증 요소 유형]

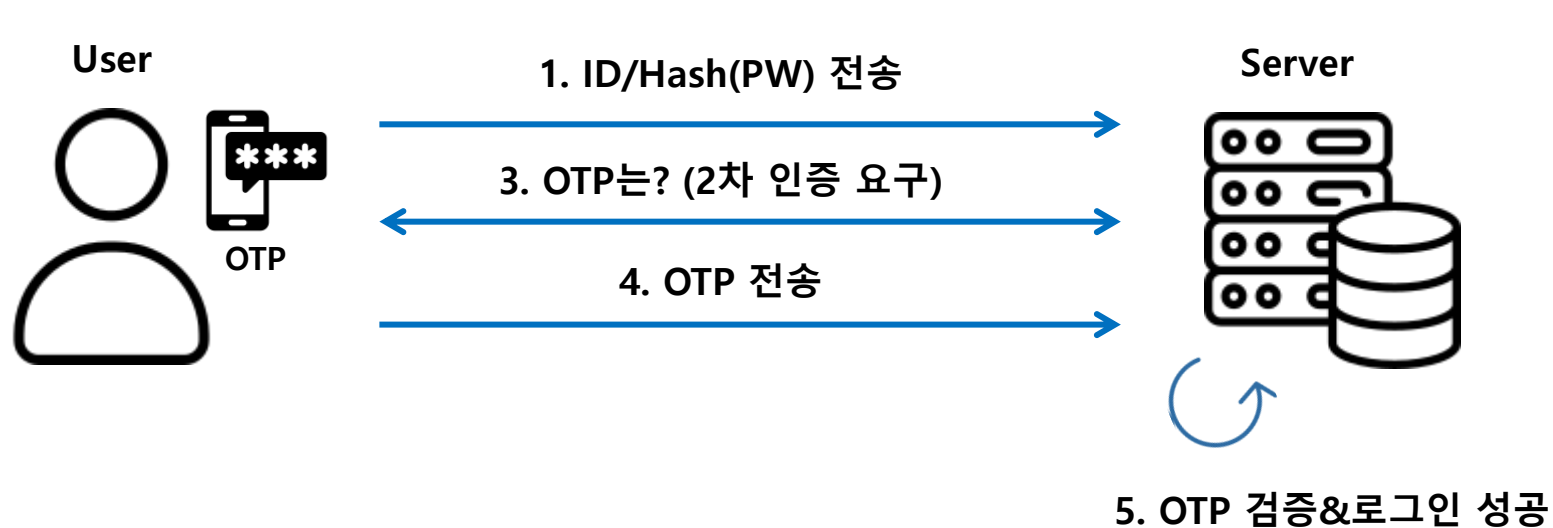
인증 요소	설명	예시
지식 기반 (Something You Know)	알고 있는 지식 활용	비밀번호, 패턴, PIN, 질문 등
소유 기반 (Something You Have)	소유하고 있는 인증수단 활용	OTP, 공인인증서, 주민등록증 등
생체 기반 (Something You Are)	생체정보 활용	지문, 얼굴, 홍채, 정맥 등
행동 기반 (Something You Do)	사용자의 행동 패턴을 분석하여 활용	음성, 필체, 제스처 등



기존 인증 시스템

➤ 다중 요소 인증 (Multi Factor Authentication, MFA)

- 비밀번호(지식 기반) + *OTP(소유 기반)을 통한 인증 흐름



2. DB에서 ID/PW 검증

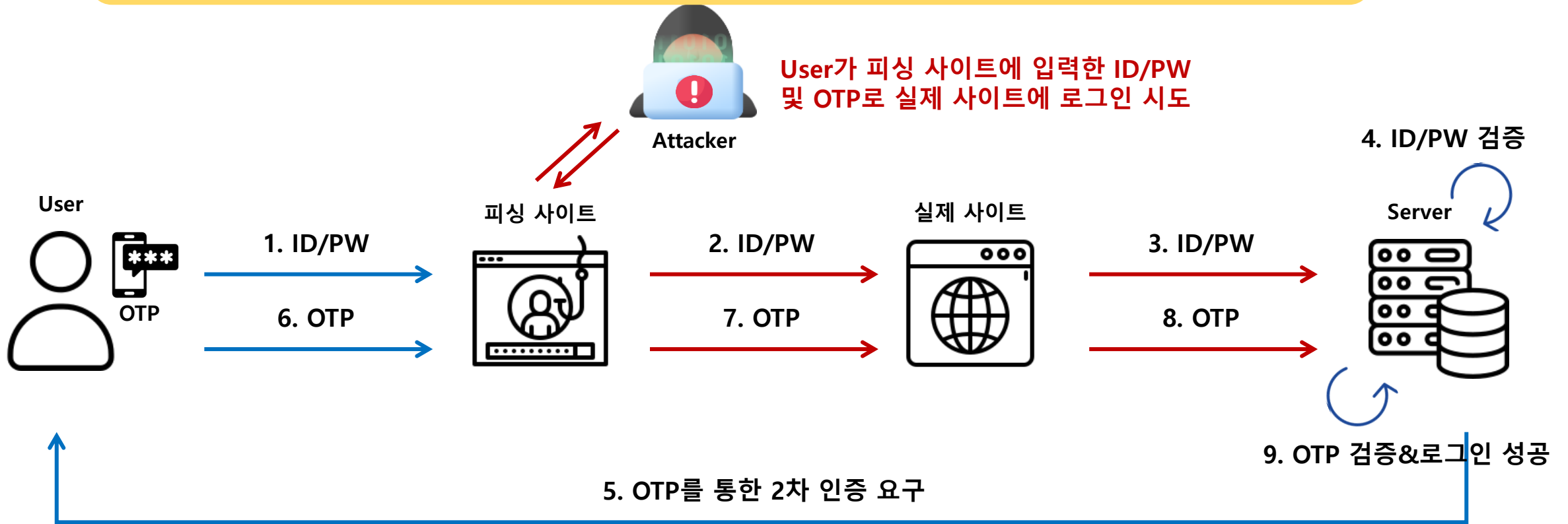
Index	ID	Hash(PW)
1	user1	Hash('inf0sec')
...	...	...
301	alice	Hash('hoseo134')

1. 기존 인증 시스템

➤ 다



패스워드 기반 인증 방식보다 안전하지만,
추가 인증으로 인해 **사용자 편의성이 저하**되며, 여전히 피싱공격에 취약함



Fast Identity Online(FIDO)

➤ FIDO란?

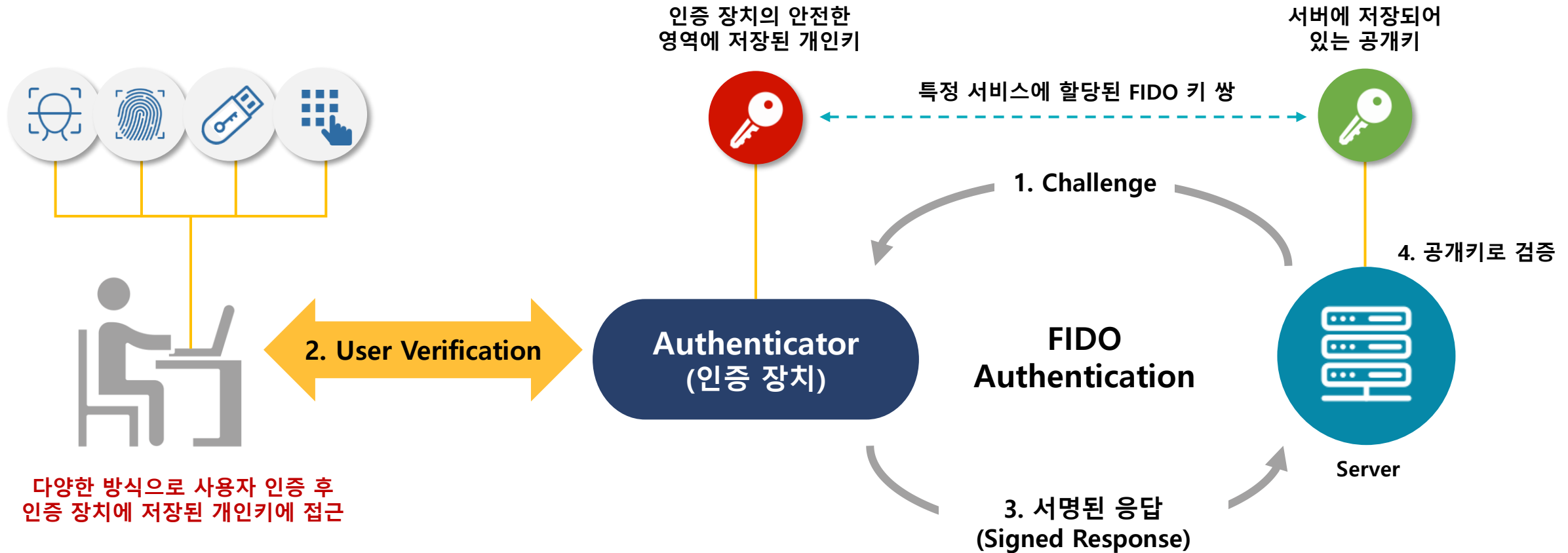
- 비밀번호에 대한 의존도를 줄이고 온라인 신원 검증의 보안성과 편리성을 향상시키기 위해 FIDO Alliance에서 개발한 글로벌 인증 표준

➤ FIDO 인증 기술의 특징

- 공개키 암호 기술을 기반으로 하는 인증 시스템
- 각 서비스(도메인)마다 고유한 인증을 위한 정보(Credential) 생성
 - 도메인 별로 고유한 키를 사용하여 로그인하기 때문에 피싱 방지가 가능
- 인증에 사용하는 비밀 정보가 서버에 전달되지 않으며, 사용자가 소유한 디바이스의 안전한 공간에 저장됨

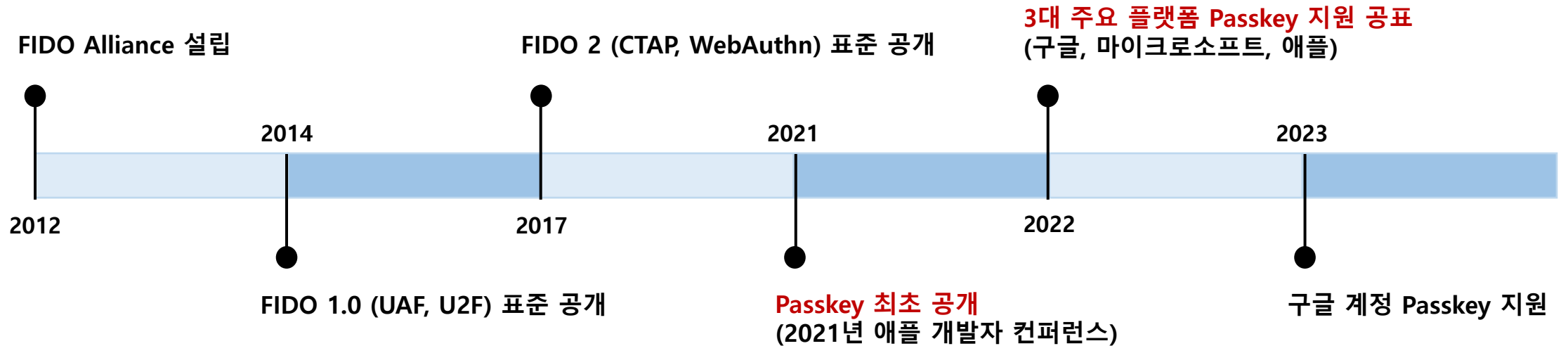
Fast Identity Online(FIDO)

➤ FIDO 인증 개념



2.1 Fast Identity Online(FIDO)

➤ FIDO의 연혁

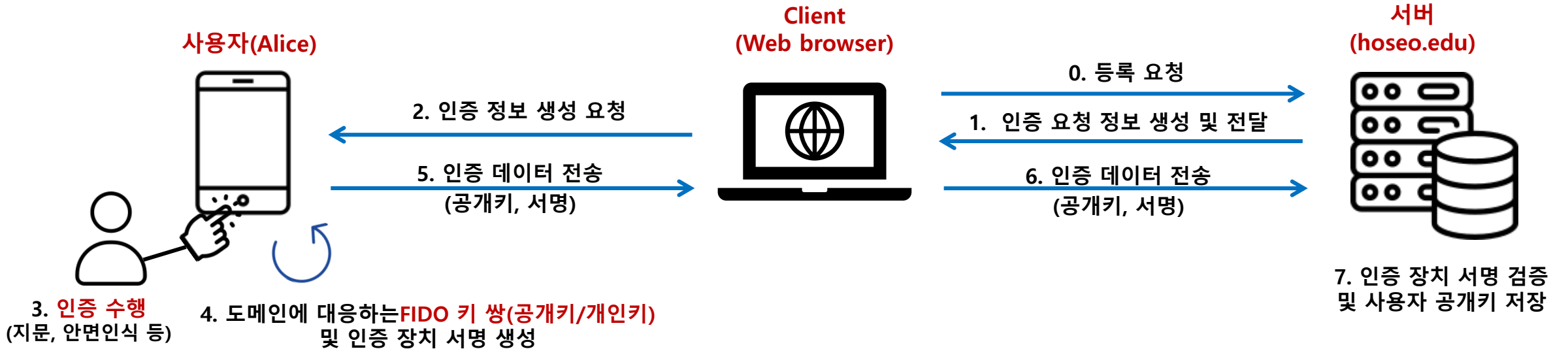


2.3 FIDO 2 – 동작 과정

➤ 등록 과정 – 특정 서비스에 Credential(FIDO 키 쌍) 생성



- ✓ FIDO 개인키는 인증 기기에 안전하게 저장
- ✓ Server는 FIDO 공개키만 저장



[Authenticator 저장 정보]

Credential ID	서버 ID	Username	Private key
...	...	...	...
3sRf...	hoseo.edu	Alice	afew7g23s...

[Server 저장 정보]

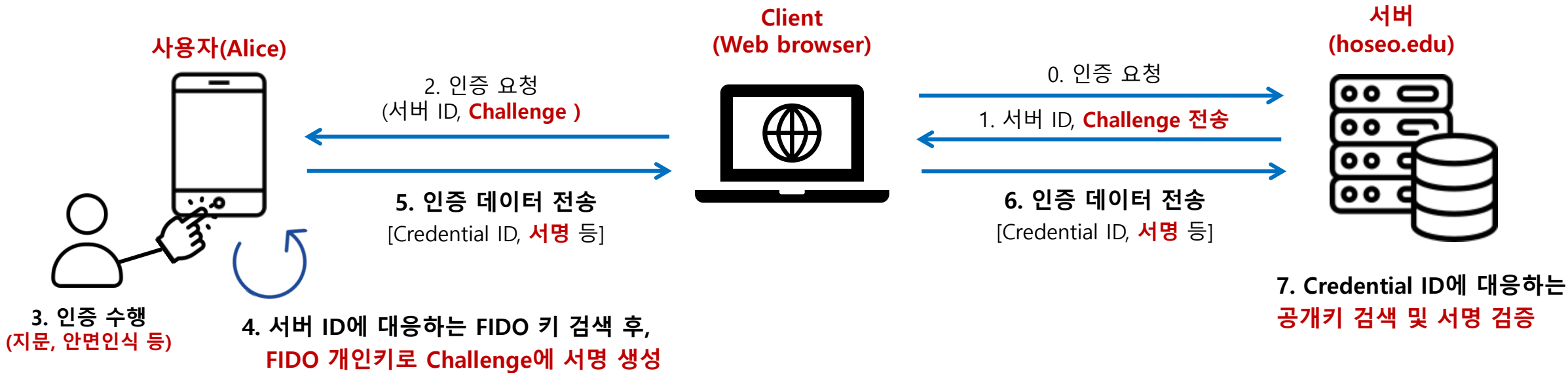
Username	Credential ID	Public key
...	...	...
Alice	3sRf...	3zohn1jes...

2.3 FIDO 2 – 동작 과정

➤ 인증 과정 – 등록된 Credential로 서비스에 로그인



✓ 서버는 사용자가 해당 서비스에 대한 Credential을 가지고 있음을 확인!!



[Authenticator 저장 정보]

Credential ID	서버 ID	Username	Private key
...	...	...	...
3sRf...	hoseo.edu	Alice	afew7g23s...

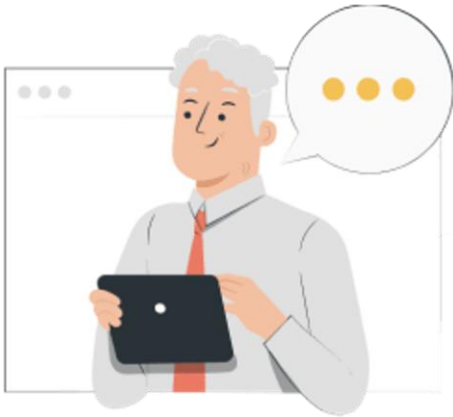
[Server 저장 정보]

Username	Credential ID	Public key
...	...	...
Alice	3sRf...	3zohn1jes...

FIDO 정리

➤ 패러다임의 전환

<기존 지식 기반 자격 증명에서>



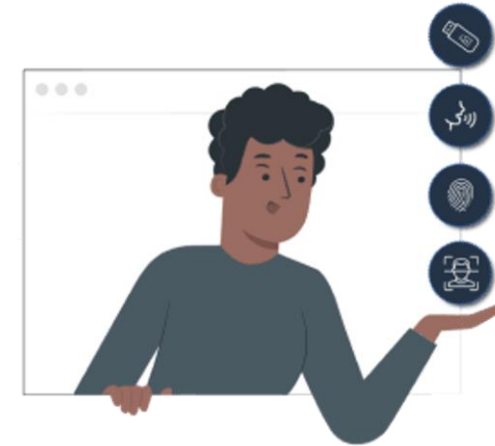
- 비밀번호가 서버에 저장되어 유출 위험 존재
- SMS OTP 등 2차인증을 수행해도 피싱 공격에 취약



각종 위험에 취약



<소유 기반 자격 증명으로>



- 비밀정보는 디바이스에 저장됨(never on server)
- 로컬 디바이스에서는 생체인식을 이용한 인증 수행
- 기기 변경 시에도 기존의 키 쌍을 사용할 수 있도록 보안 클라우드에 안전하게 저장(Multi-device FIDO credentials, 예) passkeys)



피싱 방지

FIDO 정리



비밀번호 없는 로그인

- 비밀번호 없이 **공개키 암호 기반의 키 쌍을 생성하여, 전자서명** 하는 방식으로 로그인
- 서명생성에 사용하는 **개인키는 생체인증을 이용하여 접근**
- 사용자가 비밀번호 설정하고, 기억하고, 변경해야 하는 번거로움 해소



언제 어디서나 사용

- 스마트폰, PC, 웹 등 다양한 환경에서 사용 가능
- 인증에 사용하는 키 쌍을 클라우드에 백업하여, 기기 교체/분실 시에도 **재등록 없이 사용 가능**



해킹과 피싱에 대한 보안

- 서비스 별로 **고유한 키를 생성하여 피싱 위험 원천 차단**
- 인증에 사용하는 개인키는 사용자의 디바이스에서 생체 인증 등을 통해 접근 가능하므로, **해킹으로부터 계정을 안전하게 보호**